DOC ID: SEC-TOOLS-INVENTORY-2026-V1
SECURITY STANDARD: OWASP / CWE / CVSS v3.1
CLASSIFICATION: TECHNICAL ARCHITECTURE

Sential AI — فهرس ودليل محركات وأدوات الفحص الأمني

حصر وتوصيف تفصيلي لكافة أدوات الفحص الديناميكي (DAST)، المصدري (SAST)، سلاسل الإمداد (SCA)، ومولدات الترقيع (أكتوبر 2026)

+14	+970	5	5
محركات فحص هجومي (DAST)	قواعد فحص كود مصدري (SAST)	أدوات سلاسل التوريد والـ IaC	منصات ترقيع تلقائي مدعومة

1 محركات الفحص الهجومي الديناميكي (DAST & Active Probing Engines)

14 أداة ومحرك نشط

Active Form XSS ⚡ Fuzzer

`form-fuzzer.service.ts`

يقوم باستخراج نماذج الـ HTML وحقول الإدخال (`<input>`, `<textarea>`)، وحقن Canaries تشخيصية ذكية (`<sential_probe_xss"'><canary`) عبر طلبات GET و POST وفحص الارتداد غير المشفر بالـ DOM.

`CWE-79 / OWASP A03` `Active Fuzzing` `Node.js DOM Parser`

Raw SSL/TLS 🔒 Socket Auditor

`ssl-cipher-auditor.service.ts`

يفتح اتصال Raw TCP Socket مباشر عبر المنفذ 443 ويفحص شهادات X.509، الصلاحية بالأيام، الموقعة ذاتياً، ويختبر تفاوض الاتصال بالبروتوكولات الضعيفة (SSLv3, TLS 1.0, TLS 1.1).

`CWE-326 / CWE-295` `Raw Socket 443` `Node tls/net`

Server-Side 🧩 Template Injection

`ssti-auditor.service.ts`

يحقن تعبيرات رياضية تقييمية مثل `{{7*7}}` و `${7*7}` في معلمات الروابط مع إجراء **Baseline Verification** مسبق لمنع أي إيجابيات كاذبة.

`CWE-1336 / CWE-94` `Active Injection` `Baseline Zero-FP`

LFI & Safe OS 📁 Command Auditor

`lfi-cmd-auditor.service.ts`

يفحص تخطي المسارات للملفات الحساسة (`etc/passwd`, `win.ini/`) وحقن كواشف الـ Echo الآمنة تماماً بدون تخريب السيرفر أو تسريب بيانات.

`CWE-22 / CWE-78` `Safe Canary Echo` `Regex Signature`

Cloud Storage ☁ Bucket Recon

`cloud-leak-auditor.service.ts`

يولد أسماء الحاويات السحابية بناءً على النطاق والاسم التجاري للمنظمة، ويفحص القراءة العامة لسلات **AWS S3**, **Google Cloud Storage**, و **Azure Blob Storage**.

`CWE-200 / CWE-538` `Multi-Cloud HEAD` `S3 / GCS / Azure`

BOLA / IDOR 🆔 Tampering Auditor

`idor-auditor.service.ts`

يرصد المعرفات الرقمية المتسلسلة في مسارات الـ APIs ويقوم بتجربة المعرف التالي (`id + 1`) لفحص هل يرجع السيرفر كود 200 وبيانات مستخدم آخر دون تدقيق للصلاحيات.

`CWE-639 / OWASP API1` `Path Tampering` `Session Prober`

Access Control & 🚪 Bypass Auditor

`access-control-auditor.service.ts`

يفحص لوحات الإدارة غير المحمية (`admin`,`/dashboard/`)، وتخطي الـ Reverse Proxy عبر رؤوس `X-Original-URL` و `X-Rewrite-URL` وكشف قواعد البيانات المتروكة.

`CWE-306 / CWE-285` `Header Bypass Probe` `Route Dictionary`

GraphQL & WebSocket Auditor

`graphql-auditor.service.ts`

يفحص مسارات GraphQL لاكتشاف فتح خاصية الـ Introspection وسحب الـ Schema الكاملة، وتجربة تخطي الـ WebSocket handshake دون توكنات تحقق.

`CWE-200 / CWE-284` `Introspection Query` `GraphQL AST`

JWT Token Security 🔑 Auditor

`jwt-auditor.service.ts`

يفحص توكنات JWT ويختبر ثغرة التوقيع الفارغ (`alg:none`)، ضعف المفاتيح السرية الشائعة، التوكنات منتهية الصلاحية، وفك التشفير لكشف البيانات الحساسة المضمنة بالـ Payload.

CWE-347 / CWE-327 | Cryptographic Audit | JWT Signature

Prototype 🧪 Pollution Prober

`prototype-pollution.service.ts`

يرسل حمولات اختبار الـ Prototype Pollution عبر معلمات الـ JSON والـ Query parameters مثل `proto__[sential_polluted]=1_` ويرصد استجابة السيرفر وتلوث الكائنات.

CWE-1321 | Object Injection | JSON Payload Prober

SSRF & Cloud 🌐 Metadata Hunter

`ssrf-auditor.service.ts`

يفحص معلمات الروابط وحقن عناوين الـ Loopback والـ Metadata السحابية مثل `http://169.254.169.254/latest/meta-data/` لاكتشاف تسريب بيانات الـ IAM والتفويض.

CWE-918 / OWASP A10 | Metadata Traversal | AWS / GCP / Localhost

OAST Out-of-Band 📡 Callback Server

`oast.service.ts`

محرك التفاعل الخارجي لرصد الثغرات العمياء (Blind SQLi, Blind SSRF, Blind XSS) عن طريق رصد نداءات الـ DNS والـ HTTP الراجعة لسيرفر الاستماع الخاص بالمنصة.

CWE-918 / CWE-89 | Out-of-Band Listener | DNS / HTTP Canaries

Nuclei & OWASP 🎯 ZAP Adapters

`nuclei.adapter.ts / zap.adapter.ts`

محولات قياسية متوافقة مع مخرجات ZAP DAST وقوالب Nuclei المفتوحة، توفر مصفوفات فحص للثغرات الشائعة والـ CVEs المنشورة حديثاً.

CWE Multi-family | DAST Standards | Template Scanner

Port Scanner & 🛰️ CMS Fingerprinter

`whatweb.adapter.ts / wpscan.adapter.ts`

مسح المنافذ القياسية (21, 22, 80, 443, 3000, 8080)، استخراج بصمات السيرفرات (Nginx, Apache, IIS)، وكشف أنظمة إدارة المحتوى وقوالب WordPress وإصداراتها.

CWE-200 | Reconnaissance | Socket / HTTP Banners

2 محركات فحص الكود المصدري الساكن (SAST & Semantic Analysis)

+970 قاعدة ومعالجة AST

📚 SentinelAI 970+ CWE Knowledge Base

`knowledge-base.service.ts`

قاعدة بيانات ضخمة مدمجة تحتوي على 970 تعريف تفصيلي للضعف الأمني، تقدم لكل ثغرة: الوصف الدقيق، مسار الاستغلال، الأثر التشغيلي، وكود الترقيع الموصى به رسمياً.

`CWE Definitions 970` Knowledge Engine

`JSON Micro-DB`

🔍 AST Semantic & Taint Tracking (CodeQL)

`codeql.adapter.ts / ai-reasoning.service.ts`

تحليل شجرة البنية المجردة (AST) وتتبع مسار تدفق البيانات من المدخلات غير الموثوقة (`req.query`, `req.body`) وصولاً إلى دوال التنفيذ الخطرة (Sinks) مثل `eval()` و `exec()`.

`CWE-20 / CWE-78 / CWE-89` Taint Analysis

`Source-to-Sink`

⚡ Semgrep AST Pattern Matcher

`semgrep.adapter.ts`

مطابقة الأنماط البرمجية الخطرة داخل كود JavaScript, TypeScript, Python، و PHP، لاكتشاف استخدام دوال التشفير الضعيفة مثل `Math.random()` و `md5`.

`CWE-330 / CWE-327` AST Regex / Patterns

`Polyglot Rules`

🔑 Gitleaks Credential & Secret Hunter

`gitleaks.adapter.ts`

فحص الإنتروبيا (Shannon Entropy) والتعبيرات النمطية المتقدمة لكشف مفاتيح AWS، وتوكنات GitHub (`ghp_`)، ومفاتيح Stripe، والشهادات الخاصة داخل ملفات الكود والـ Git History.

`CWE-798 / CWE-532` Secret Detection

`High-Entropy Regex`

3 فحص سلاسل التوريد والاعتماديات (SCA & Cloud IaC Layer)

أمان المكتبات والـ Containers

📦 npm-audit & OSV Live Scanner

`npm-audit.adapter.ts / osv-scanner.adapter.ts`

مطابقة ملفات الاعتماديات (`package.json`, `package-lock.json`) مع قاعدة بيانات الثغرات المفتوحة OSV وقاعدة بيانات أمان GitHub لرصد الـ CVEs المنشورة.

`CWE-1395 / OWASP A06` Dependency Audit

`OSV API Sync`

🛡️ Trivy & Checkov (IaC & Containers)

`trivy.adapter.ts / checkov.adapter.ts`

فحص ملفات Dockerfile وتكوينات الـ Infrastructure as Code (Terraform, Kubernetes, CloudFormation) لرصد التكوينات الخاطئة وتشغيل الحاويات بصلاحيات الـ Root.

`CWE-732 / CWE-250` IaC Misconfiguration

`Container Security`

4 محركات الترقيع الآلي وحماية السيرفرات (Remediation & Hardening Layer)

توليد كود إنتاجي فوري

⚙️ Multi-Platform Server Hardening Generator

`platform-patch.service.ts`

يولد تلقائياً قواعد ترقيع وتكوينات حماية جاهزة للتحميل الفوري لخمس منصات رئيسية: ****Nginx** (`nginx.conf`), **Apache** (`.htaccess`), **Caddy** (`Caddyfile`), **Express.js** (`helmet`), و ****Django** (`settings.py`).

`Server Hardening` `Auto Config Generator` `Platforms Ready 5`

🔧 In-Place Code Remediation Engine

`git-remediation.service.ts`

يولد Unified Diff قياسي بتنسيق Git، ويقوم بتصحيح الأكواد المصابة تلقائياً على القرص لثغرات SQL Injection عبر Prepared Statements، و XSS عبر DOMPurify، و Command Injection عبر execFile.

`Git Unified Diff` `Source Code Patch` `Automatic Fix`

5 محركات الارتباط، قياس الخطورة والذكاء الاصطناعي (Core Intelligence)

دقة حسابية وخوارزميات FIRST

🔗 Cross-Engine Correlation & Dedup

`findings-deduplication.service.ts`

توليد بصمات رقمية فريدة (Fingerprints) لمنع تكرار الثغرات، وربط نقاط الضعف السطحية (DAST) بأماكنها المباشرة في الكود (SAST) ورفع درجة الثقة إلى **CONFIRMED / VERIFIED**.

`Fingerprint Hashing` `Data Normalization`

📐 Mathematical CVSS v3.1 Calculator

`cvss-calculator.service.ts`

تطبيق معادلات FIRST الرسمية بدقة متناهية لحساب متجهات الخطورة الأساسية (AV, AC, PR, UI, S, C, I, A) وإخراج الدرجة الرقمية من 0.0 إلى 10.0.

`FIRST Equations` `Official Standard`

🤖 AI Security Copilot (On-Device NLP)

`ai-chat.routes.ts`

مساعد ذكي ثنائي اللغة متصل بالمعرفة الأمنية الحية وسياق الفحص يشرح الثغرات، يجيب على الأسئلة التقنية، ويوضح خطوات الاستخدام والترقيع الفورية.

`Bilingual AR / EN` `Conversational AI`

🖨️ Headless Chromium Vector PDF Generator

`scripts/export-pdf.js`

محرك توليد ملفات الـ PDF عالي الدقة عبر محرك Chromium / Edge في وضعية Headless، يضمن إنتاج ملفات PDF رسمية بألوان متناسقة، نصوص متجهة قابلة للبحث، وطباعة A4 خالية من الأخطاء.

`Chromium Engine` `PDF Renderer`

6 جدول الحصر الشامل لكافة الأدوات ومجال عملها (Master Tool Inventory)

اسم الأداة / الخدمة	الملف المصدري	التصنيف	طبيعة الفحص	الهدف الأمني الرئيسي
FormFuzzerService	`form-fuzzer.service.ts`	DAST	Active Probing	حقن النماذج وكشف الـ XSS غير المشفر بالـ DOM
SslCipherAuditorService	`ssl-cipher-auditor.service.ts`	DAST / Network	Active Socket	فحص شهادات SSL وبروتوكولات TLS 1.0/1.1 على بورت 443
SstiAuditorService	`ssti-auditor.service.ts`	DAST	Active Injection	حقن قوالب السيرفر (Jinja2/Twig/ERB) مع Baseline Zero-FP
LfiCmdAuditorService	`lfi-cmd-auditor.service.ts`	DAST	Active Probing	كشف تخطي مسارات الملفات وحقن أوامر Echo الآمنة
CloudLeakAuditorService	`cloud-leak-auditor.service.ts`	DAST / Recon	Active Recon	كشف تسريب سلات التخزين السحابية (AWS S3, GCP, Azure)
IdorAuditorService	`idor-auditor.service.ts`	DAST / Auth	Active Tampering	فحص التلاعب بالمعرفات المتسلسلة لكسر الصلاحيات (BOLA)
AccessControlAuditorService	`access-control-auditor.service.ts`	DAST / Auth	Active Probing	كشف لوحات الأدمن غير المحمية وتخطي الـ Proxy Headers
GraphqlAuditorService	`graphql-auditor.service.ts`	DAST / API	Active Query	كشف فتح الـ Introspection وسحب الـ Schema والتسريبات
JwtAuditorService	`jwt-auditor.service.ts`	DAST / Crypto	Active Audit	فحص التوقيع الفارغ (alg: none) وضعف التشفير في الـ JWT

اسم الأداة / الخدمة	الملف المصدري	التصنيف	طبيعة الفحص	الهدف الأمني الرئيسي
PrototypePollutionService	`prototype-pollution.service.ts`	DAST	Active Probing	حقن حمولات تلوث كائنات الـ JavaScript في السيرفر
SsrfAuditorService	`ssrf-auditor.service.ts`	DAST	Active Probing	حقن عناوين الـ Loopback والـ Cloud Metadata (169.254.169.254)
OastService	`oast.service.ts`	DAST / Out-of-Band	Active Listener	سيرفر استماع للنداءات الراجعة للثغرات العمياء (Blind SQLi/SSRF)
KnowledgeBaseService	`knowledge-base.service.ts`	SAST / KB	Knowledge Engine	970+ قاعدة بيانات تفصيلية وتوصيفات أمنية معتمدة عالمياً
Semgrep Adapter	`semgrep.adapter.ts`	SAST	Static Pattern	كشف الأنماط البرمجية الخطرة ومولدات العشوائية غير الآمنة
CodeQL Adapter	`codeql.adapter.ts`	SAST	Taint Analysis	تتبع تدفق المدخلات غير الموثوقة من المصدر إلى المصب
Gitleaks Adapter	`gitleaks.adapter.ts`	SAST / Secrets	Entropy Analysis	كشف مفاتيح السحابة، توكنات الـ API، والبيانات الحساسة بالكود
npm-audit & OSV Scanner	`npm-audit.adapter.ts` / `osv-scanner.ts`	SCA	Advisory Matching	مطابقة الاعتماديات مع الثغرات المنشورة عالمياً (CVEs)
Checkov & Trivy Adapters	`checkov.adapter.ts` / `trivy.adapter.ts`	IaC / Container	Static Config Audit	فحص ملفات Docker و Terraform وأمان البنية التحتية

اسم الأداة / الخدمة	الملف المصدري	التصنيف	طبيعة الفحص	الهدف الأمني الرئيسي
PlatformPatchService	`platform-patch.service.ts`	Remediation	Config Synthesis	توليد إعدادات حماية إنتاجية لـ Nginx, Apache, Caddy, Express, Django
GitRemediationService	`git-remediation.service.ts`	Remediation	Automated In-Place	تصليح الكود المصدري محلياً وإنشاء Unified Diff قياسي
CvssCalculatorService	`cvss-calculator.service.ts`	Scoring Engine	Mathematical Calc	تطبيق معادلات FIRST الرسمية لمعيار CVSS v3.1 بدقة متناهية
AI Security Assistant	`ai-chat.routes.ts`	AI / UX	Conversational NLP	مساعد ذكي ثنائي اللغة يجيب على الأسئلة ويشرح خطوات العمل